Compliance Component

DEFINITION	
Name	Host-Based Intrusion Detection Systems (HIDS)
Description	Host-Based Intrusion Detection Systems (HIDS) operate on information collected from within an individual computer system. This vantage point allows HIDS to analyze activities to determine exactly which processes and users are involved in an attack on a particular system or host. HIDS can see the outcome of an attempted attack, as they can directly access and monitor the data files and operating system processes targeted by the attack.
Rationale	The first step in delivering an efficient and secure intrusion protection strategy is accurately detecting all possible threats. To achieve this goal, multiple detection methods including HIDS should be employed to ensure comprehensive coverage. The failure to secure any State of Missouri host system with HIDS puts agencies at a much greater risk of loss. A single attack can cost millions of dollars in time spent recovering from the attack and liability for compromised data and hardware. The damage from an attack to State of Missouri services can also include inconvenience to citizens and the loss of public confidence.
Benefits	• HIDS can detect attacks that cannot be seen by a Network-Based IDS since they monitor events local to a host. • HIDS can often operate in an environment where network traffic is encrypted. • HIDS are unaffected by switched networks. • HIDS can detect, and in some cases prevent, attacks that involve software integrity breaches, such as Trojan Horses. • HIDS have the ability to monitor local files for any changes or modifications. • HIDS can see the outcome of an attempted attack since they can directly access and monitor the data files and operating system processes targeted by the attack.

ASSOCIATED ARCHITECTURE LEVELS	
List the Domain Name	Security
List the Discipline Name	Technical Controls
List the Technology Area Name	Intrusion Detection Systems
List Product Component Name	

COMPLIANCE COMPONENT TYPE	
Document the Compliance Component Type	Guideline
Component Sub-type	

COMPLIANCE DETAIL	

State the Guideline, Standard or Legislation	**General HIDS Requirements**
	• Administrators shall be trained on the IDS before implementation. Despite vendor claims of ease of use, training and/or experience are absolutely necessary to manage any IDS.
	• It is preferred to have the HIDS controlled directly from a central location(s). However, the HIDS may be agent-based where response decisions are made at the host.
	• IDS administrators shall be able to create or change policies easily.
	
	HIDS Deployment Requirements
	• HIDS shall be deployed in conjunction with Network-Based IDS to fully protect the system.
	• It is recommended that organizations install the Network-Based IDS first, followed by the HIDS installation on critical servers. Once administrators are familiar with the HIDS, it may be installed on the remainder of the organization's hosts.
	• HIDS shall be installed on any host where sensitive or critical information is stored.
	• It is preferred to install IDS Management software on a separate system from the target host being monitored.
	• It is preferred to have the HIDS use an agent-manager (server) architecture, where policy is created and modified on the manager and automatically distributed to all agents.
	• It is preferred that host agents poll the manager at periodic intervals for policy changes or new software updates.
	
	HIDS Analysis Requirements
	• HIDS shall utilize information from operating system audit trails and system logs.
	• HIDS shall have easy-to-use tools to analyze the logs.
	• HIDS shall detect, and preferably prevent, the following:
	  o System scanning (probing the target with different kinds of packets to garner information about the system, such as topology, active hosts, operating systems and software in use),
	  o Denial of Service (DoS) (slow or shut down targeted systems or hosts), and
	  o Penetration (unauthorized acquisition and/or alteration of system privileges, resources, or data).
	• HIDS shall use Misuse Detection methods (matching a predefined pattern of events describing an attack) and may also include Anomaly Detection (abnormal, unusual behavior) components.
	• Administrators shall follow a schedule for checking the results of the HIDS to ensure attackers have not modified the system.

	HIDS Response Requirements
	• HIDS shall respond in real-time.
	• It is preferred that HIDS provide active responses to intrusions by:
	  o Collecting additional information:
	  ▪ Turning up the number of events logged, or
	  ▪ Capturing all packets, not just those targeting a particular port or system.
	  o Changing the environment:
	  ▪ Terminating the connection, or
	  ▪ Reconfiguring routers and firewalls to:
	  • Block packets from the intruder's IP address,
	  • Block network ports, protocols or services, or
	  • Sever all connections that use certain network interfaces.
	• HIDS administrators shall work closely with router and firewall administrators when creating rules for routers and firewalls to ensure intruders cannot abuse the feature to deny access to legitimate users.
	• HIDS may provide passive responses requiring subsequent human action to intrusions by:
	  o Generating alarms and notifications with popup windows, cellular phones, pagers and email, or
	  o Reporting alarms and alerts using SNMP traps and plug-ins to central network management consoles.
	• All HIDS communications shall be secure and use encrypted tunnels or other cryptographic measures
	• HIDS shall create output with the following information for each intrusion detected:
	  o Time/date
	  o Sensor IP address
	  o Specific attack name
	  o Source and destination IP addresses
	  o Source and destination port numbers
	  o Network protocol used
	  o Description of the attack type
	  o Attack severity level
	  o Type of loss expected
	  o Type of vulnerability exploited
	  o Input validation (buffer overflow or boundary condition)
	  o Access validation (faulty access control mechanism)
	  o Exceptional condition
	  o Environmental (unexpected interaction with an application and the operating system or between two applications)
	  o Host Configuration

	○ Race (delay between the time a system checks to see if an operation is allowed and the time it performs the operation) ○ Design ○ Software types and versions vulnerable ○ Patch information to counter the attack ○ References to advisories about the attack or vulnerability • It is preferred that HIDS reports combine redundant attack entries and make attacks of highest importance stand out.
Document Source Reference #	NIST SP 800-31 (www.csrc.nist.gov/publications/nistpubs) Intrusion Detection Systems (IDS), NIST SP 800-18 (www.csrc.nist.gov/publications/nistpubs) CERT Guide to System and Network Security Practices (www.cert.org/security-improvement/)

Standard Organization			
Name		*Website*	
Contact Information			
Government Body			
Name	National Institute of Standards and Technology (NIST), Computer Security Resource Center (CSRC) CVE Vulnerability Search on ICAT Metabase	*Website*	http://csrc.nist.gov/ http://icat.nist.gov/
Contact Information	inquiries@nist.gov		

KEYWORDS	
List all Keywords	Honey Pot, intrusion, cracker, buffer overflows, passwords, sniffing, exploit, denial-of-service, Java, ActiveX, SMURF, DNS, probes

COMPONENT CLASSIFICATION				
Provide the Classification	☐ *Emerging*	☒ *Current*	☐ *Twilight*	☐ *Sunset*

Rationale for Component Classification	
Document the Rationale for Component Classification	

Conditional Use Restrictions	
Document the Conditional Use Restrictions	

Migration Strategy	
Document the Migration Strategy	

Impact Position Statement	
Document the Position Statement on Impact	

CURRENT STATUS			
Provide the Current Status)	☐ *In Development* ☐ *Under Review* ☒ *Approved* ☐ *Rejected*		
AUDIT TRAIL			
Creation Date	04/03/2003	*Date Accepted / Rejected*	05/14/2003
Reason for Rejection			
Last Date Reviewed		*Last Date Updated*	
Reason for Update			